

# IBS: Bezpečnost a počítačové sítě

## Email, S/MIME, PGP, SPF, DKIM, DMARC

Brno University of Technology, Faculty of Information Technology  
Božetěchova 1/2, 612 66 Brno - Královo Pole  
Vladimír Veselý, [veselyv@fit.vut.cz](mailto:veselyv@fit.vut.cz)



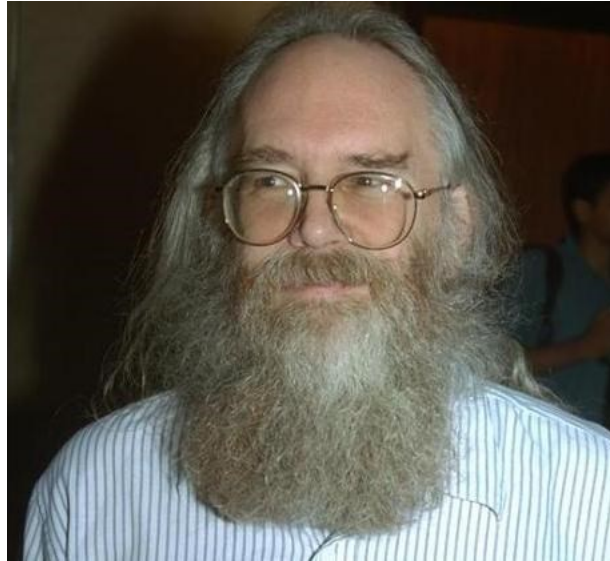
3<sup>rd</sup> March 2025

# EMAIL 101

- An estimated 347.3 billion emails are sent each day around the globe, marking a 4.3% increase from the previous year.
- There are approximately 4.26 to 4.37 billion email users worldwide in 2023
- There are over 7.9 billion email accounts
  - Seznam.cz has 25 millions accounts (2022), Gmail.com has 1.9 billion accounts (2023)
- Regarding the number of email accounts an individual has, the average is reported to be between 1.75 and 1.9 email accounts per user.
- 46% to 63% percentage of emails opened on mobile
- On average, a person receives about 121 emails per day.
- The average emails sent per day at work by an office employee is around 40 per day
- <https://venngage.com/blog/email-stats/>

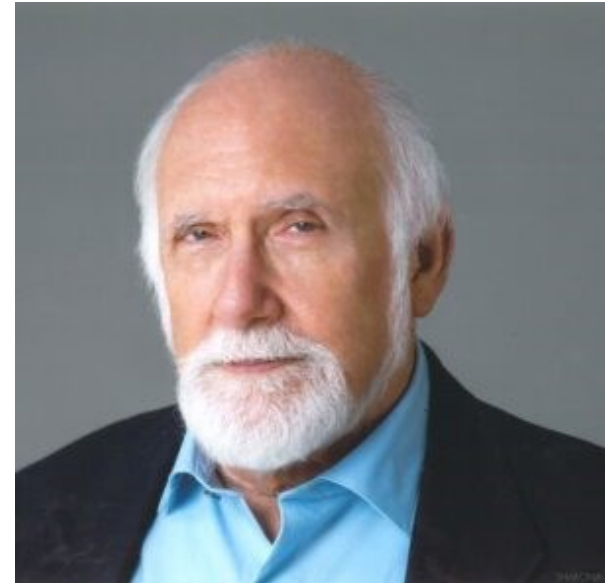
- Volume of Emails Sent
  - Nearly 300 billion emails are sent and received daily. This number is expected to reach 376.4 billion by 2025. Email traffic saw a significant increase during the COVID-19 pandemic, especially from March to July 2020.
- Business vs. Personal Emails
  - An average person sends and receives 121 business emails per day. Business and consumer emails combined are projected to exceed 319 billion daily in 2021.
- Email Open Rates
  - 42% of emails are opened on smartphones and tablets, and 28.4% on iPhones. The average open rate for all industries is 18%, with government emails seeing a 50% increase in click-through rates during the pandemic.
- Email Service Providers
  - Gmail leads with 1.5 billion active users, followed by Apple iPhone email client with a 48% market share.
- Consumer Email Behavior
  - 58% of users check email first when they go online. US adults spend an average of 5 hours daily checking email, with 80% frequently opening work emails.
- <https://financesonline.com/email-statistics/>

- RFC 821
- RFC 2821
- RFC 5321



- Jon Postel

- John Klensin

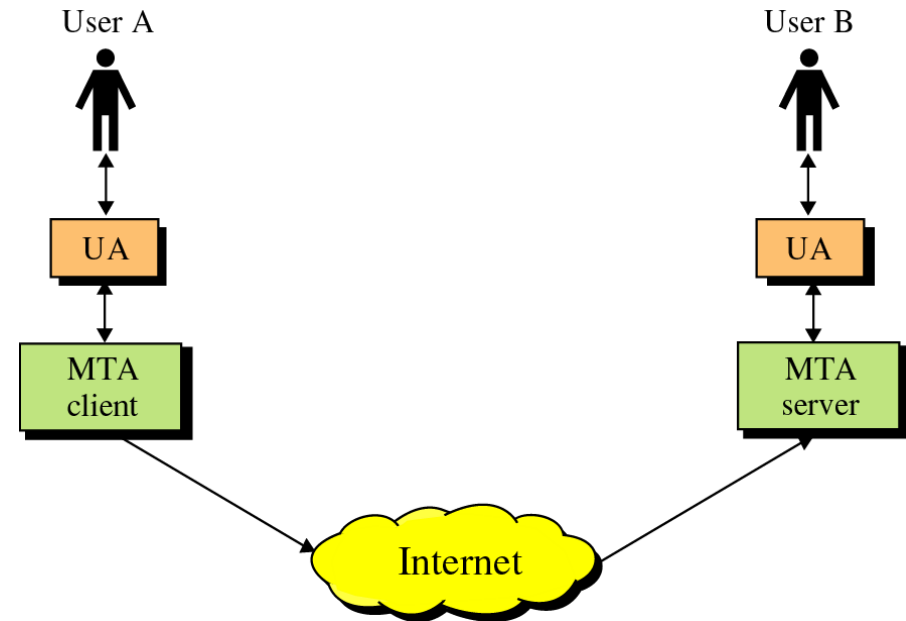


- **User Agent**

- An application with user interface used by individuals to compose, send, receive, and manage email messages.
- It typically interacts with mail servers via protocols like SMTP (for sending) and IMAP or POP (for receiving).

- **MTA**

- Software system responsible for transferring email messages between servers using standardized protocol.
- MTAs work behind the scenes to route and deliver emails from the sender's server to the recipient's server, handling tasks like queue management, retry mechanisms, and error reporting

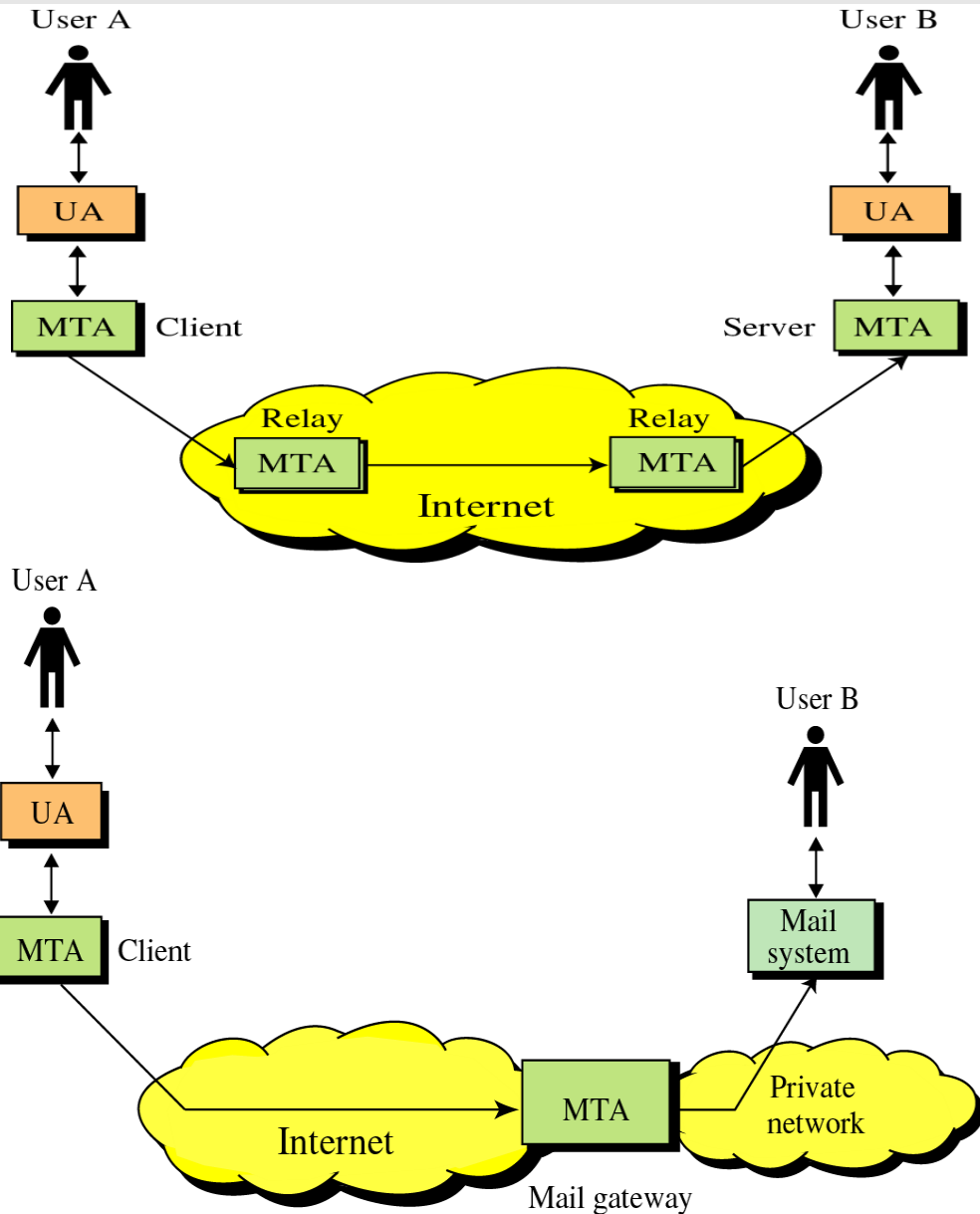


- **Relays**

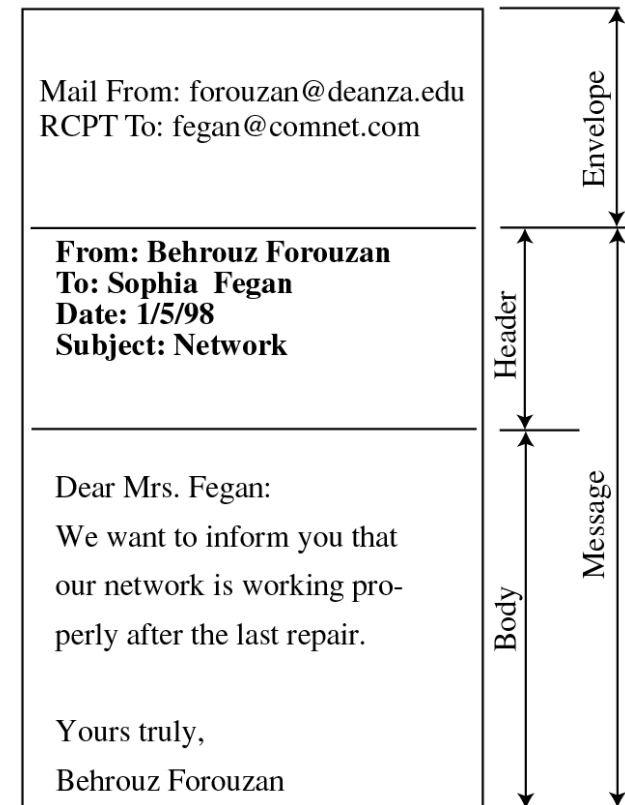
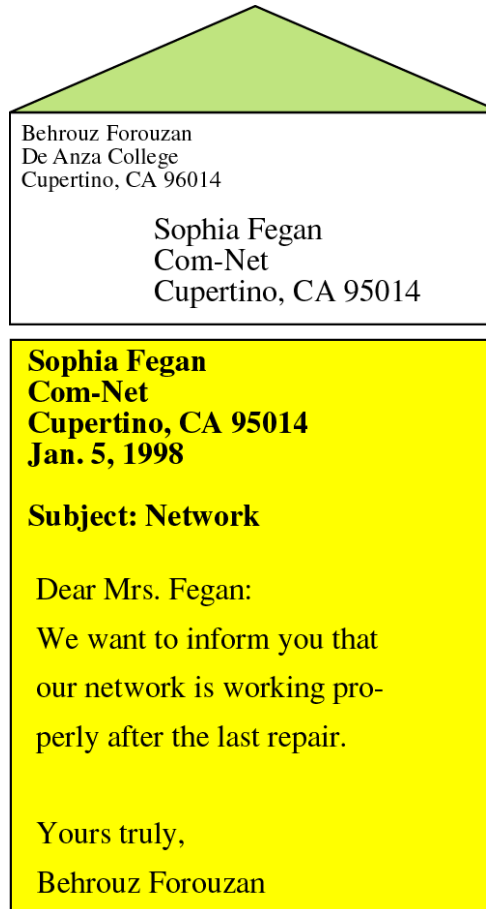
- Mail server that passes email messages from one server to another.
- It acts as an intermediary in the email delivery process, forwarding messages to their final destination.
- Often used by organizations to route outbound emails, mail relays must be carefully configured to prevent abuse (such as spamming) by unauthorized users.

- **Gateway**

- Server or system that serves as an entry or exit point for email traffic, performing various functions such as filtering, security scanning, and routing between different email systems or networks.
- Essentially, it acts as a bridge between internal and external email communications, helping to enforce security policies, detect spam or malware, and ensure proper email delivery.



- Mail is a file
- **Envelope**
  - sender address
  - receiver address
  - other information
- **Message**
  - Mail Header – defines the sender, the receiver, the subject of the message, and some other information
  - Mail Body – Contains the actual information in the message

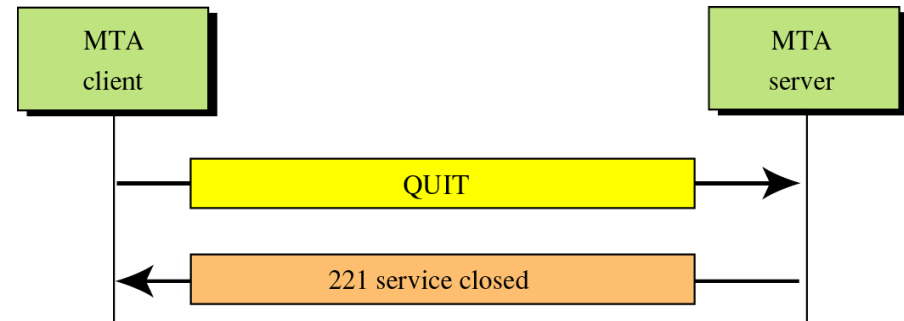
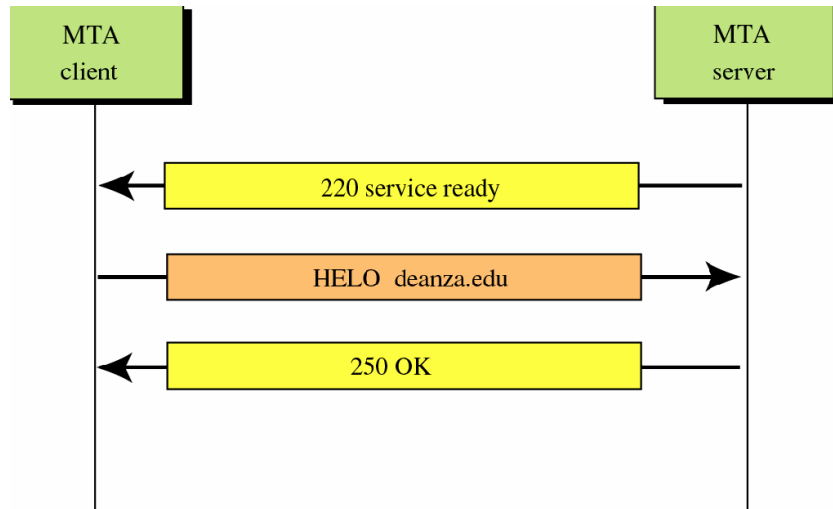


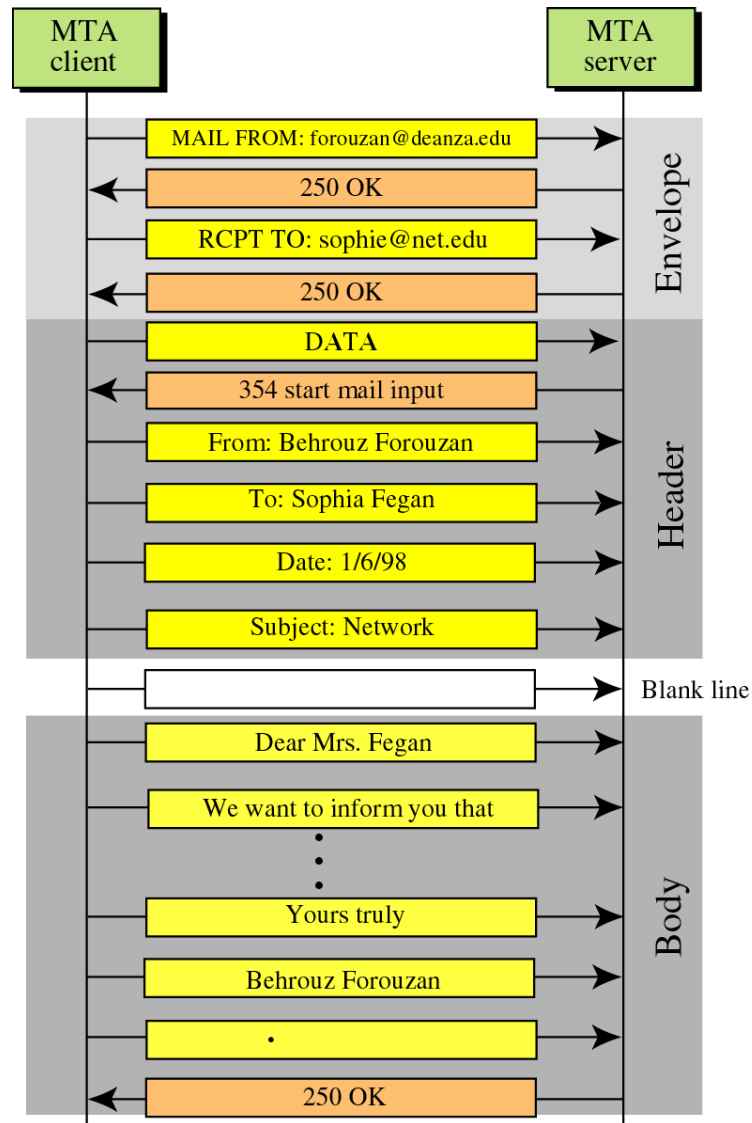
- **MIME** is a standard that extends the format of email to support text in character sets beyond ASCII, as well as attachments of multimedia content like images, audio, video, and application files.
- **Content-Type**
  - `text/plain,`  
`text/html,`  
`image/jpeg,`  
`application/pdf`
- **Encoding**
  - `base64`
- **Multi-part Messages**
  - `multipart/mixed,`  
`multipart/alternative`

- runs over TCP
- Well-known ports
  - 25
  - 465: TLS
  - 587: STARTTLS
- STARTTLS command
  - upgrade of connection for SMTP, POP, IMAP
- Authentication
  - No auth
  - Insecure password
  - Encrypted password
  - Kerberos
  - NTLM

| Keyword     | Command form                        | Description                                                                 | Usage              |
|-------------|-------------------------------------|-----------------------------------------------------------------------------|--------------------|
| <b>HELO</b> | HELO<SP><domain><CRLF>              | It provides the identification of the sender i.e. the host name.            | Mandatory          |
| <b>MAIL</b> | MAIL<SP>FROM : <reverse-path><CRLF> | It specifies the originator of the mail.                                    | Mandatory          |
| <b>RCPT</b> | RCPT<SP>TO : <forward-path><CRLF>   | It specifies the recipient of mail.                                         | Mandatory          |
| <b>DATA</b> | DATA<CRLF>                          | It specifies the beginning of the mail.                                     | Mandatory          |
| <b>QUIT</b> | QUIT<CRLF>                          | It closes the TCP connection.                                               | Mandatory          |
| <b>RSET</b> | RSET<CRLF>                          | It aborts the current mail transaction but the TCP connection remains open. | Highly recommended |
| <b>VRFY</b> | VRFY<SP><string><CRLF>              | It is use to confirm or verify the user name.                               | Highly recommended |
| <b>NOOP</b> | NOOP<CRLF>                          | No operation                                                                | Highly recommended |
| <b>TURN</b> | TURN<CRLF>                          | It reverses the role of sender and receiver.                                | Seldom used        |
| <b>EXPN</b> | EXPN<SP><string><CRLF>              | It specifies the mailing list to be expanded.                               | Seldom used        |
| <b>HELP</b> | HELP<SP><string><CRLF>              | It send some specific documentation to the system.                          | Seldom used        |
| <b>SEND</b> | SEND<SP>FROM : <reverse-path><CRLF> | It send mail to the terminal.                                               | Seldom used        |
| <b>SOML</b> | SOML<SP>FROM : <reverse-path><CRLF> | It send mail to the terminal if possible; otherwise to mailbox.             | Seldom used        |
| <b>SAML</b> | SAML<SP>FROM : <reverse-path><CRLF> | It send mail to the terminal and mailbox.                                   | Seldom used        |

| Status Code                  | Message/Category                                           | Description                                                                                                   |
|------------------------------|------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------|
| <b>2xx Success</b>           |                                                            |                                                                                                               |
| 211                          | System status, or system help reply                        | Provides system status or help information.                                                                   |
| 214                          | Help message                                               | A help message explaining the server's commands.                                                              |
| 220                          | Service ready                                              | The server is ready to accept a new connection (e.g., at connection start-up).                                |
| 221                          | Service closing transmission channel                       | The server is closing the connection after a command (e.g., after QUIT).                                      |
| 250                          | Requested mail action okay, completed                      | Indicates successful completion of the requested action.                                                      |
| 251                          | User not local; will forward to <forward-path>             | The recipient is not local, but the server will forward the message.                                          |
| 252                          | Cannot VRFY user, but will accept message                  | The server cannot verify the recipient, but will attempt delivery anyway.                                     |
| <b>3xx Redirection</b>       |                                                            |                                                                                                               |
| 354                          | Start mail input; end with <CRLF>.<CRLF>                   | The server is ready to receive the message body. Terminate input with a single period on a line.              |
| <b>4xx Temporary Failure</b> |                                                            |                                                                                                               |
| 421                          | Service not available, closing transmission channel        | The server is temporarily unavailable; connection will be closed.                                             |
| 450                          | Requested action not taken: mailbox unavailable            | The recipient's mailbox is unavailable (e.g., busy or temporarily inaccessible).                              |
| 451                          | Requested action aborted: local error in processing        | A local error prevented the action from being completed.                                                      |
| 452                          | Requested action not taken: insufficient system storage    | The server lacks sufficient storage space to complete the request.                                            |
| <b>5xx Permanent Failure</b> |                                                            |                                                                                                               |
| 500                          | Syntax error, command unrecognized                         | The server did not recognize the command due to a syntax error.                                               |
| 501                          | Syntax error in parameters or arguments                    | There is a syntax error in the command's parameters or arguments.                                             |
| 502                          | Command not implemented                                    | The server does not support the command.                                                                      |
| 503                          | Bad sequence of commands                                   | Commands were sent in an improper sequence.                                                                   |
| 504                          | Command parameter not implemented                          | A command parameter is not supported by the server.                                                           |
| 550                          | Requested action not taken: mailbox unavailable            | The requested action failed because the recipient's mailbox is unavailable (e.g., nonexistent or restricted). |
| 551                          | User not local; please try <forward-path>                  | The recipient is not local; the sender should try another route for delivery.                                 |
| 552                          | Requested mail action aborted: exceeded storage allocation | The message size exceeds the storage allocation available for the recipient.                                  |
| 553                          | Requested action not taken: mailbox name not allowed       | The email address syntax is incorrect, or the mailbox name is not allowed.                                    |
| 554                          | Transaction failed                                         | A general error indicating that the transaction has failed, often due to security or policy restrictions.     |





- **DO NOT DO THAT ON ANY REAL DOMAIN OR REAL ACCOUNTS!!!**

```
veselyv@merlin: ~$ telnet kazi.fit.vutbr.cz 25
Trying 2001:67c:1220:808::93e5:80c...
Connected to kazi.fit.vutbr.cz.
Escape character is '^]'.
220 kazi.fit.vutbr.cz ESMTP Sendmail 8.18.1/8.18.1; Mon, 3 Mar 2025 11:01:26 +0100 (CET)
MAIL FROM:<mgregr@fit.vut.cz> BODY=7BIT
250 2.1.0 <mgregr@fit.vut.cz>... Sender ok
RCPT TO:<ibstest@mailinator.com>
250 2.1.5 <ibstest@mailinator.com>... Recipient ok
DATA
354 End data with <CR><LF>.<CR><LF>
From:<donald@president-trump.eu>
To:<ibstest@mailinator.com>
Subject: Test

Test123
.
250 2.0.0 523A1QSd087369 Message accepted for delivery
QUIT
221 2.0.0 kazi.fit.vutbr.cz closing connection
Connection closed by foreign host.
veselyv@merlin: ~$
```

- RFC 3501
- RFC 9501
- Version 4rev2

- Mark Crispin



- RFC 4550
  - LEMONADE profile
  - P-IMAP

- Alexey Melnikov

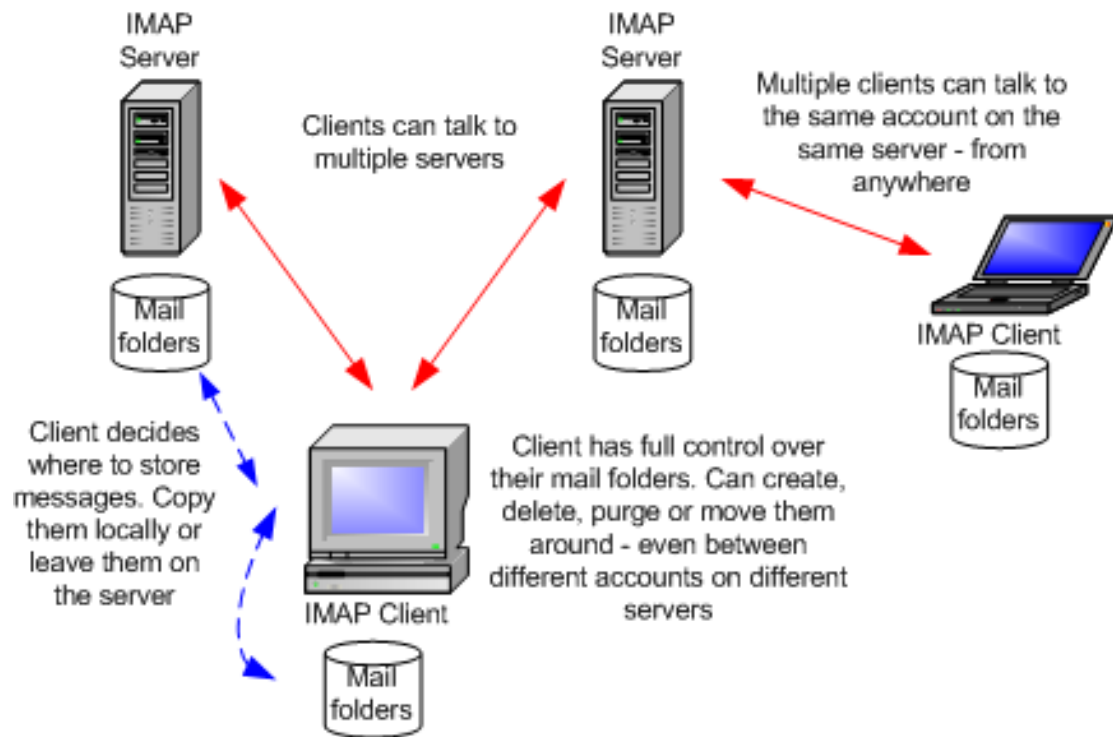


- Barry Leiba

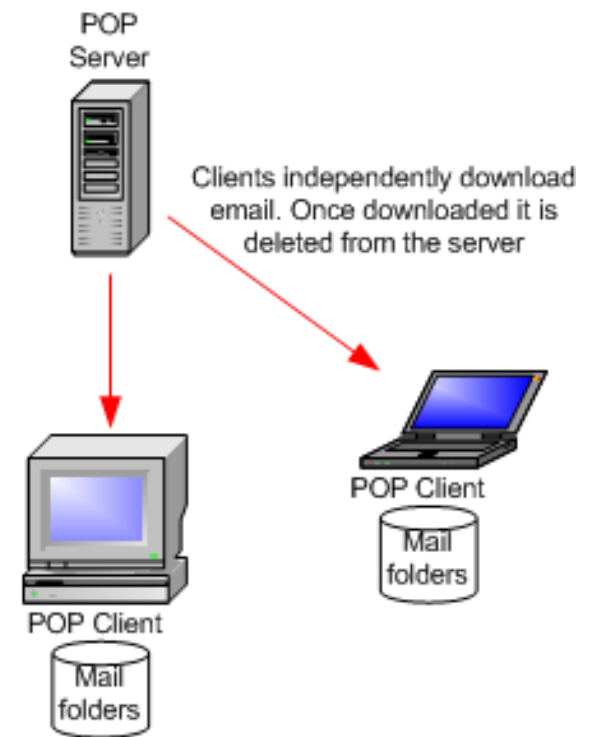
- runs over TCP
- Well-known ports
  - 143: STARTTLS
  - 993: TLS
- Authentication
  - Normal password
  - Encrypted password
  - Kerberos
  - NTLM
  - TLS Certificate
  - OAuth2

- IMAP clients can create, rename, and/or delete mailboxes on the server, and copy messages between mailboxes
  - Mail in Sent folder is pushed from UA towards server!
- IMAP clients often stay connected as long as the user interface is active and download message content on demand
- POP needs exclusive access, while IMAP supports simultaneous sessions to the same inbox
- IMAP protocol allows clients to retrieve any of the individual MIME parts separately and also to retrieve portions of either individual parts or the entire message
- IMAP provides a mechanism for a client to ask the server to search for messages meeting a variety of criteria

## IMAP



## POP



| Command     | Description                                                                   |
|-------------|-------------------------------------------------------------------------------|
| LOGIN       | Authenticates a user to the server                                            |
| SELECT      | Selects a mailbox for read/write access                                       |
| EXAMINE     | Selects a mailbox in read-only mode                                           |
| CREATE      | Creates a new mailbox                                                         |
| DELETE      | Deletes an existing mailbox                                                   |
| RENAME      | Renames a mailbox                                                             |
| SUBSCRIBE   | Marks a mailbox as one to be listed by LSUB                                   |
| UNSUBSCRIBE | Removes a mailbox from the subscription list                                  |
| LIST        | Lists available mailboxes                                                     |
| LSUB        | Lists subscribed mailboxes                                                    |
| STATUS      | Retrieves mailbox status information                                          |
| APPEND      | Adds a message to a mailbox                                                   |
| CHECK       | Asks the server to perform a checkpoint of the currently selected mailbox     |
| CLOSE       | Closes the currently selected mailbox, expunging messages marked for deletion |
| EXPUNGE     | Permanently removes messages marked for deletion                              |
| SEARCH      | Searches for messages that match given criteria                               |
| FETCH       | Retrieves data associated with a message, such as headers or flags            |
| STORE       | Alters data associated with a message (e.g., setting flags)                   |
| COPY        | Copies messages to another mailbox                                            |
| UID         | Executes commands using unique identifiers for messages                       |
| NOOP        | Performs no operation; used to keep the connection alive                      |
| LOGOUT      | Terminates the session                                                        |

| Response  | Category     | Description                                                                                                                      |
|-----------|--------------|----------------------------------------------------------------------------------------------------------------------------------|
| * OK      | Untagged     | Indicates that the server is ready or that the previous command completed successfully.                                          |
| * PREAUTH | Untagged     | Indicates that the server has pre-authenticated the connection, allowing the session to start without a separate login.          |
| * BYE     | Untagged     | Indicates that the server is closing the connection, usually due to an error or shutdown.                                        |
| OK        | Tagged       | Confirms that a client-issued command completed successfully.                                                                    |
| NO        | Tagged       | Indicates that the command was understood but could not be completed, typically due to a temporary failure or condition.         |
| BAD       | Tagged       | Indicates a protocol or syntax error; the server did not understand the command.                                                 |
| +         | Continuation | Signals that the server is ready to accept additional data (often used when the server awaits more information from the client). |

# MAIL PROBLEMS

- **Email Spoofing**
  - Attackers can easily forge the "From" address in an email, making it appear as though the message comes from a trusted sender. This undermines the trust users have in email communications.
- **Forwarding and Relay Issues**
  - Emails that are forwarded or relayed through multiple servers can lose or alter authentication data, making it difficult to verify the original sender's identity.
- **Compromised Accounts**
  - Even when authentication protocols are in place, a legitimate account may be compromised. This allows attackers to send genuine-looking emails from a valid domain, bypassing many checks.
- **Complexity and Misconfigurations**
  - Setting up and maintaining email authentication systems is complex. Misconfigurations (such as incorrect DNS records) can lead to false positives or negatives, causing legitimate emails to be marked as suspicious or allowing illegitimate emails to pass as authentic.

- **Unencrypted Transmission**

- Emails are often sent over unencrypted channels, especially when legacy systems are in use. This makes them vulnerable to interception by unauthorized parties.
- Inadequate or misconfigured encryption settings (for example, not enforcing TLS or using outdated encryption methods) can weaken confidentiality protections and allow data to be compromised.

- **Storage Vulnerabilities**

- Once received, emails are stored on multiple servers—both on the sender's and receiver's side. If these storage systems are not adequately secured, attackers or insiders with access might view confidential content.
- Many email systems do not implement end-to-end encryption by default. Without it, emails can be decrypted at intermediary points like mail servers, increasing the risk of unauthorized access.

- **Third-Party Access**

- Service providers may have policies or vulnerabilities that allow access to stored emails. This means that even if emails are encrypted in transit, they might be decrypted and inspected by third parties once they reach a server.

- **Phishing and Social Engineering**

- Users may inadvertently expose confidential information by responding to phishing emails or through social engineering that trick them into disclosing sensitive data.

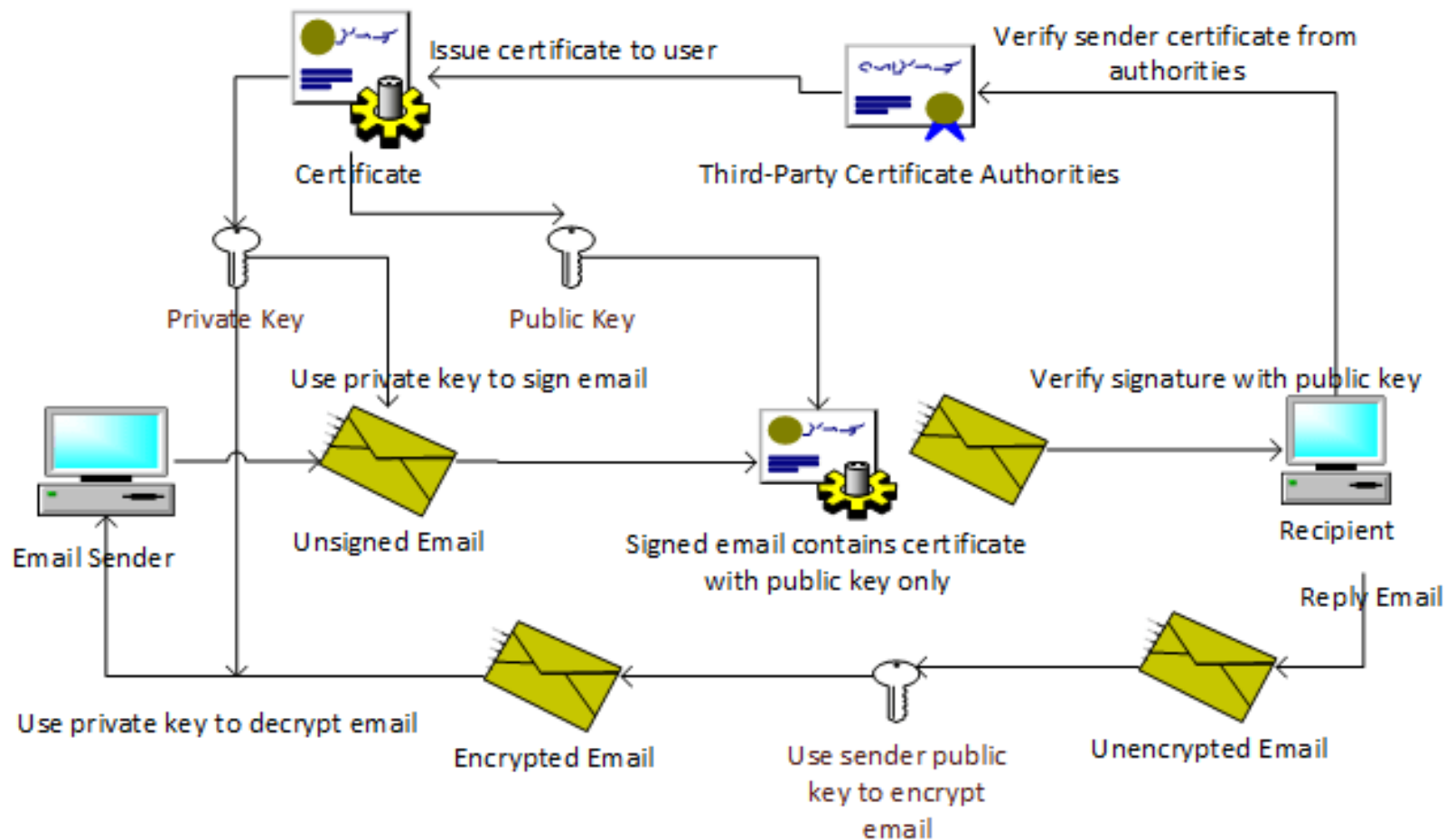
- **Sender Impersonation**
  - Without systems that confirm an email's true origin, malicious senders can easily disguise themselves as legitimate entities. This makes it far easier to trick recipients into trusting fraudulent emails.
- **Unreliable Trust Signals and Diminished Reputation**
  - When there's no reliable way to verify that an email is coming from a genuine source, filtering systems lack the trusted markers they need to effectively distinguish between legitimate messages and spam. This often results in more unwanted messages reaching inboxes.
- **Lack of Accountability**
  - In the absence of mechanisms that provide feedback or reports on authentication failures, domain owners cannot easily detect or respond to abuse. This lack of accountability enables spammers to repeatedly exploit vulnerabilities.
- **Ease of Mass Distribution**
  - Without checks to validate who is allowed to send messages on behalf of a domain, attackers can use compromised systems or botnets to distribute large volumes of spam, overwhelming both mail servers and end users.

- **160 billion spam emails are sent every day**, with 46% of the 347 billion daily emails sent, considered spam (numbers recorded for 2023).
- The **majority of people (96.8%)** have received **spam messages** in some form.
- The **U.S. sends the most spam emails**, with **8 billion per day** on average followed by **China with 7.6 billion** per day.
- The **most common topic** of spam emails is **prizes and giveaways**, followed by **job opportunities**, and **banking**.
- Over **two-thirds (68.8%)** of people who had received spam and/or phishing messages reported their **mental health being impacted** at least a little as a result.
- **Financial institutions** are most commonly targeted by business phishing attacks, with **27.7% of scam messages** being received by companies in this sector.
- **Delivery services** were the most common subject of spam text messages in the U.S. in the first half of 2023, with over **1.1 billion scam texts relating to this topic**.
- **Men aged 65 and over** receive the **most spam calls** with an average of **35.5 calls per month**, while **men aged 18-34** receive the **fewest (14.2)**.
- The ten countries that send the most spam emails **produce 2,184 metric tonnes of CO2 every day, or 797,160 over the course of one year** from spam emails alone. In one day, that's equivalent to **5.3 million miles** driven in a conventional gas car, or **1.9 billion miles** over the course of a year.
- <https://www.emailtooltester.com/en/blog/spam-statistics/>
- <https://techxplore.com/news/2019-07-future-spam-online-intrusions.html>

End-to-End Security

# SMIME AND PGP

- RFC 8551 for securing email through encryption (achieving confidentiality) and/or digital signatures (achieving authenticity).
- Relies on Public Key Infrastructure (PKI) to manage digital certificates and cryptographic keys.
  - The sender encrypts the email using the recipient's public key and attaches a digital signature created with the sender's private key.
  - The recipient uses their private key to decrypt the message and the sender's public certificate to verify the signature.
- Widely supported by major email clients, ensuring broad compatibility



```
1 From: =?iso-8859-2?Q?Vladim=EDr_Vesel=FD?= <ivesely@fit.vutbr.cz>
2 To: <igreg@fit.vutbr.cz>
3 Subject: Podepisuji
4 Date: Thu, 21 Apr 2016 11:40:14 +0200
5 Message-ID: <00c101d19bb1$cf051af0$6d0f50d0$@fit.vutbr.cz>
6 X-Mailer: Microsoft Outlook 15.0
7 Thread-Index: AQFBEbyf1hG/EXV4TsYPHwoYB2kvBA==
8 X-OldEid: 0000000A3E822C1B3A5454DA5BB6F5AE6D8DB170700C3B68E10F77511CEB4CD00A
9 MIME-Version: 1.0
10 Content-Language: cs
11 Content-Type: multipart/signed;
12     protocol="application/x-pkcs7-signature";
13     micalg=SHA1;
14     boundary="-----_NextPart_000_00B5_01D19BC2.8F3BB2B0"
15
16 This is a multipart message in MIME format.
17
18 -----_NextPart_000_00B5_01D19BC2.8F3BB2B0
19 Content-Type: multipart/alternative;
20     boundary="-----_NextPart_001_00B6_01D19BC2.8F3BB2B0"
21
22 -----_NextPart_001_00B6_01D19BC2.8F3BB2B0
23 Content-Type: text/plain;
24     charset="iso-8859-2"
25 Content-Transfer-Encoding: 7bit
26
27 Ahoj
28
29 -----_NextPart_000_00B5_01D19BC2.8F3BB2B0
30 Content-Type: application/pkcs7-signature;
31     name="smime.p7s"
32 Content-Transfer-Encoding: base64
33 Content-Disposition: attachment;
34     filename="smime.p7s"
35
36
37 MIAGCSqGSib3DQEHAqCAMIACAQExCzAJBgUrDgMCGGUAMIAGCSqGSib3DQEHAQAooIIOTTCBuYw
38 ggTOoAMCAQICBF7c4DswDQYJKoZIhvcNAQELBQAwgaoxCzAJBgNVBAYTAKNaMQ0wCwYDVQQHDARC
39 cm5vMRcwFQYDVQQIDA5DemVjaCBSZXhB1YmxpYzEmMCQGA1UECgwdQnJubyBVbm12ZXJzaXR5IG9m
```

- PGP created by Phil Zimmermann, who became a subject of U.S.Gov investigation for for allegedly violating the *Arms Export Control Act*
- RFC 9580 and OpenPGP provides encryption with public key or symmetric cryptographic algorithms, digital signatures, compression, and key management.



| Function            | Algorithms Used                                                 | Description                                                                                                                                                                                                                         |
|---------------------|-----------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Digital signature   | DSS/SHA or RSA/SHA                                              | A hash code of a message is created using SHA-1. This message digest is encrypted using DSS or RSA with the sender's private key, and included with the message.                                                                    |
| Message encryption  | CAST or IDEA or Three-key Triple DES with Diffie-Hellman or RSA | A message is encrypted using CAST-128 or IDEA or 3DES with a one-time session key generated by the sender. The session key is encrypted using Diffie-Hellman or RSA with the recipient's public key, and included with the message. |
| Compression         | ZIP                                                             | A message may be compressed, for storage or transmission, using ZIP.                                                                                                                                                                |
| Email compatibility | Radix 64 conversion                                             | To provide transparency for email applications, an encrypted message may be converted to an ASCII string using radix 64 conversion.                                                                                                 |
| Segmentation        | —                                                               | To accommodate maximum message size limitations, PGP performs segmentation and reassembly.                                                                                                                                          |

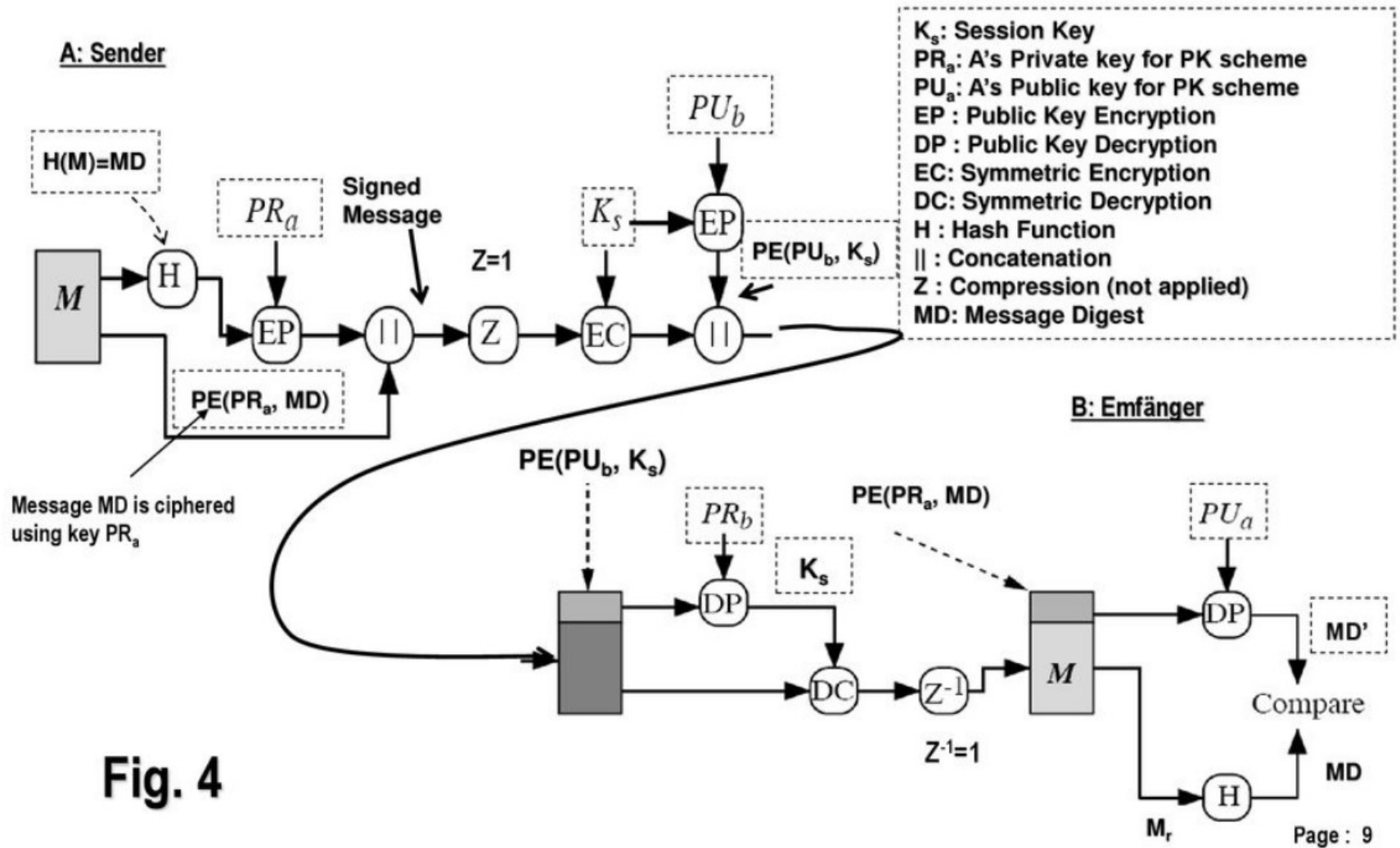
- As a default, PGP compresses the message, using the ZIP compression algorithm, after applying the signature and before encryption.



- PGP uses radix-64 conversion to map groups of three octets into four ASCII characters. Also appends a CRC for data error checking.
- PGP automatically segments messages that are too large. This is done after all of the other steps, including radix-64 conversion. Thus, signature and session key appear only once.

- **Key Management**

- A crucial aspect of PGP is its decentralized approach to key management, PGP does not leverages PKI
  - Users generate their own key pairs and share public keys through key servers or directly.
  - Trust is established through a "web of trust," where users endorse each other's public keys rather than relying on a centralized authority.
  - <https://pgp.mit.edu/pks/lookup?search=polcak&op=index>
- While PGP is most commonly associated with email encryption, it is also used for securing files, communications, and data storage.



```
From: =?UTF-8?Q?Vladim=C3=ADr_Vesel=C3=BD?= <veselyv@fit.vutbr.cz>
To: <hakim.boulahya@spaceapplications.com>
Subject: PGP Test
Date: Thu, 20 Feb 2020 09:25:04 +0100
Message-ID: <00b301d5e7c7$41787860$c4696920$@fit.vutbr.cz>
MIME-Version: 1.0
Content-Type: multipart/alternative;
    boundary="-----_NextPart_000_00B4_01D5E7CF.A33DA3B0"
X-Mailer: Microsoft Outlook 16.0
Content-Language: cs
Thread-Index: AQJW23DQvV+fS5yR9G/oAUo4DDPCbA==
X-OLkEid: 00000000282BD258CC379843A5AA4B01824A779E0700C3B68E10F7751
```

This is a multipart message in MIME format.

```
-----_NextPart_000_00B4_01D5E7CF.A33DA3B0
Content-Type: text/plain;
    charset="UTF-8"
Content-Transfer-Encoding: 7bit
```

-----BEGIN PGP MESSAGE-----

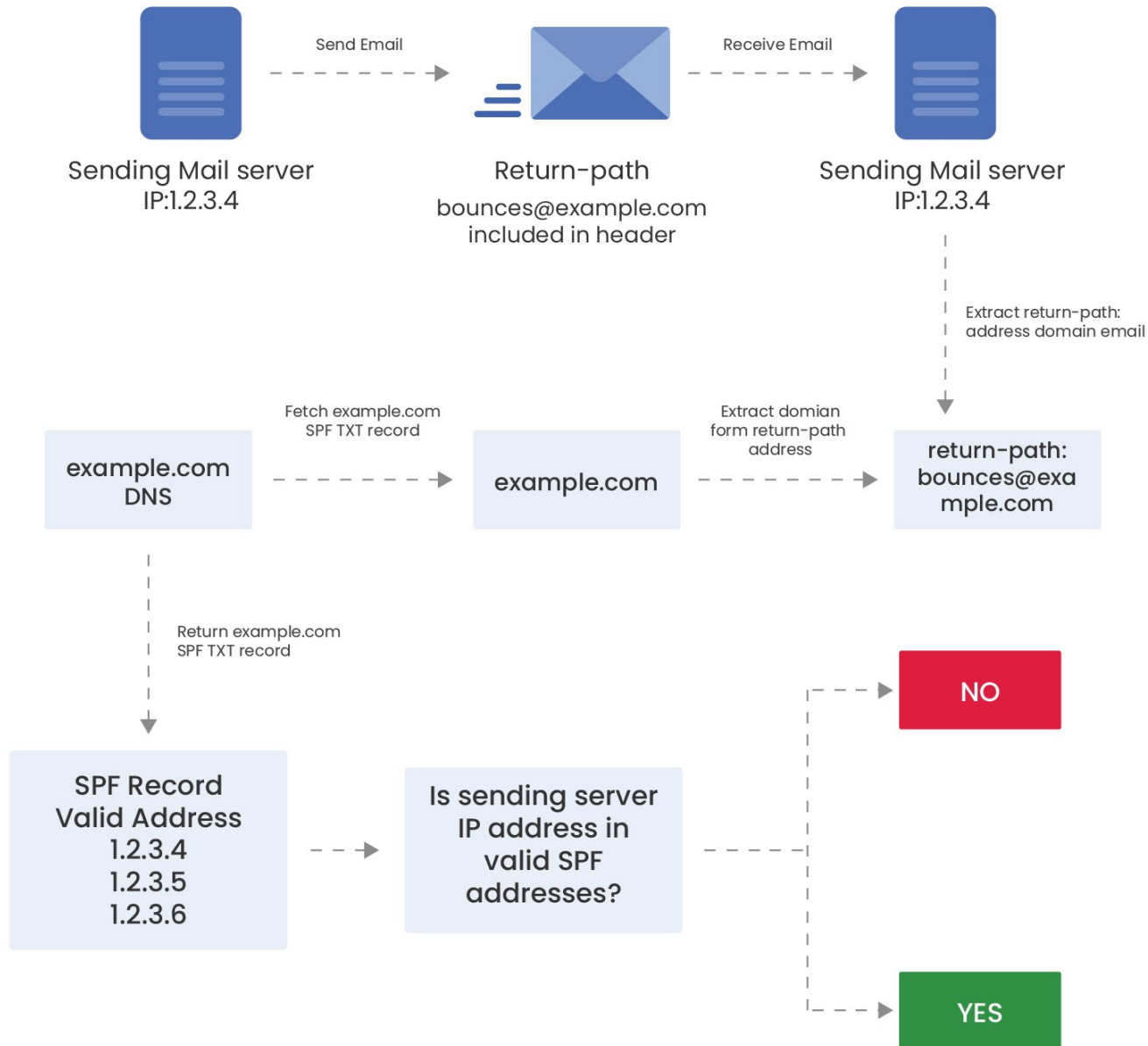
```
hQIMA8RFUfwuEczXARAAyW9Xq7mZ3fJo+lk2/ULv9opT+hRjXBJL0Uq+fQ1rs6nn
AaNiV/HT/TP0BatmQKE8mgcxwh23VkDkUjo1UxmvgJdKen5LUIbMuhlz4PGXk5sC
+JLA4wPlXQwlen/Fg6Us5BGKH6Z5Z9RRRQA1xnj7FZaRfZP8vSdTaRcO3AbnOvYA
kkyPTjkuzyJIr5CqLhC3kMRu1ycCdISsWBceahovcQjSh11gZzJbyH1N97HHidC8
0UsYf2BgnOT6D6s2UmOQF0UuRfoxFbkbm31/RV6DJDFp8NiDvj2IYk6a/bQH5Opw
SLEnAtLbnm/qGnsBddz+mrV+PzBO+y8ORczLywrTS3oCMUHgi5RmJ2zNK/Q4NluE
HxyeTTEwXankum2Wt5vf2prPom1zaVklZdDhy1huF1xteRDWDKA3nDQHR+XI0eLs
```

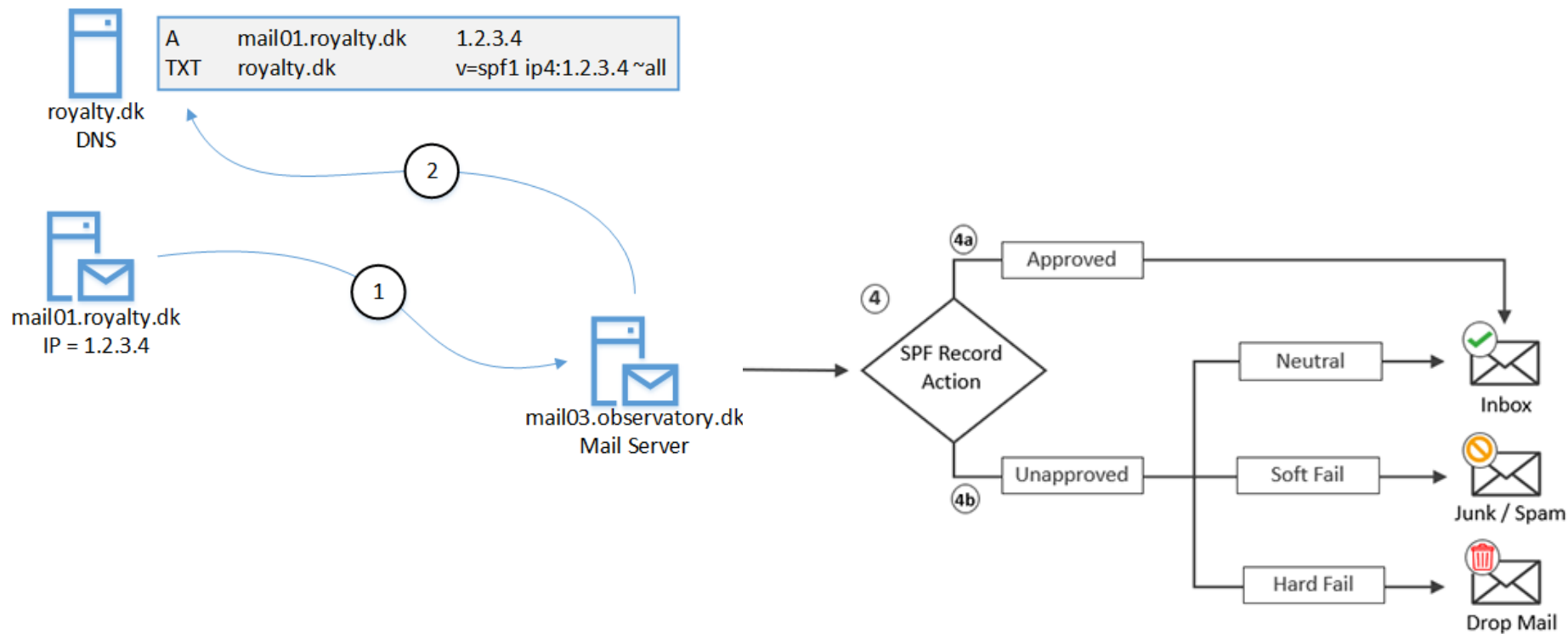
**SPF**

- **SPF** is an email authentication protocol designed to detect and prevent sender address forgery defined in RFC 7208.
  - It helps email receivers determine if incoming messages from a domain are sent by servers authorized by that domain's administrators.
  - Prevents spoofing and enhances trust
- Improves reputation
  - having SPF is better than not having it
- Enhances security
  - makes it more difficult for attackers to impersonate a domain
- Provides transparency
  - domain owners can monitor unauthorized use by analyzing email logs and SPF validation results

- A domain owner publishes an SPF record in the DNS. This record is stored as a **TXT record** and specifies which IP addresses or hostnames are allowed to send email on behalf of the domain.
- **fit.vutbr.cz**
  - `v=spf1`  
`a:kazi.fit.vutbr.cz`  
`a:eva.fit.vutbr.cz`  
`ip4:147.229.12.8`  
`ip6:2001:67c:1220:808::93e5:80c`  
`ip4:147.229.176.14`  
`ip6:2001:67c:1220:8b0::93e5:b00e`  
`a:list.fit.vutbr.cz`  
`ip4:147.229.9.34`  
`ip6:2001:67c:1220:809::93e5:922 ~all`
- **demo**
  - `v=spf1 ip4:192.0.2.1`  
`ip4:198.51.100.0/24 a mx`  
`include:mailservice.example.com -all`
- **Syntax and semantics**
  - `v=spf1`: Identifies the version of SPF being used.
  - `ip4:192.0.2.1`: Authorizes a specific IPv4 address.
  - `ip4:198.51.100.0/24`: Authorizes a range of IPv4 addresses.
  - `a`: Authorizes the IP address found in the A record of the domain.
  - `mx`: Permits servers listed in the domain's MX records.
  - `include`: Authorizes external domains (such as third-party email services) to send on behalf of the domain.
  - `-all`: Indicates that any server not matched by the earlier mechanisms is not permitted to send email for this domain (a hard fail).

- Mechanisms define the methods to authorize senders
  - `ip4/ip6`: Specify individual IP addresses or ranges.
  - `a`: Authorizes the IP address returned by the domain's A record.
  - `mx`: Uses the IP addresses in the domain's MX records.
  - `include`: Permits other domains' SPF records to be included in the evaluation.
- Qualifiers modify the effect of each mechanism
  - `+`: Pass (this is the default and can be omitted).
  - `-`: Fail; messages from non-authorized IPs should be rejected.
  - `~`: SoftFail; messages might be accepted but marked as suspicious.
  - `?`: Neutral; no definitive judgment is made.



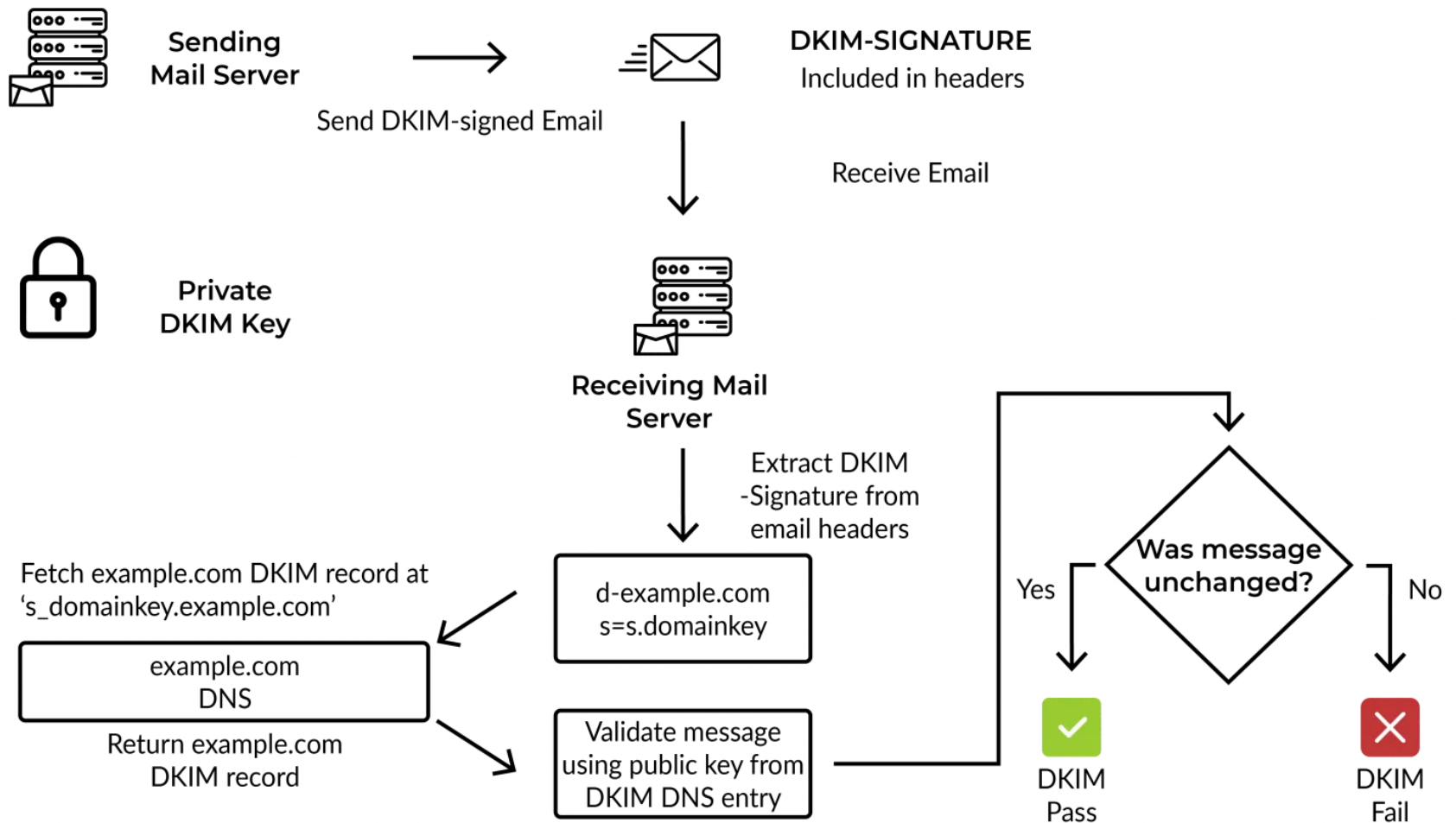


**DKIM**

- **DKIM** (standardized in RFC 6376) is an email authentication method that uses cryptographic techniques to verify that a message was indeed sent by the purported domain and that its contents have not been altered during transit.
- **Email Integrity**
  - DKIM ensures that an email's content remains unchanged from the moment it is signed by the sender to when it is received. This provides assurance that the message has not been tampered with.
- **Sender Authentication**
  - By verifying the digital signature in the email header, recipients can confirm that the email originates from a domain authorized by the sender, reducing the likelihood of spoofed messages.
- **Enhancing Trust and Deliverability**
  - When mail servers see that an email passes DKIM checks, they are more likely to consider it trustworthy, which can help improve deliverability and reduce spam filtering.

- Private/Public key pair RSA/ED25519 for signing, SHA-1/SHA-256 for integrity
- Special DNS DKIM record of type TXT
  - DKIM records are stored under a specialized name
    - `[selector]_domainkey.[domain]`
  - Record value consist of:
    - v=DKIM1: Version of DKIM being used, always set to "1"
    - k: Key type
    - p: The public key used for verification, represented as a long string of characters
  - <https://mxtoolbox.com/SuperTool.aspx?action=dkim%3afit.vutbr.cz%3amx1&run=toolpage>
- Mail server
  - Upload private key, which is used for signing

- The digital signature is attached to the email as a new header field
- This header includes several parameters
  - v=DKIM1: Specifies the version.
  - a=: Indicates the signing algorithm (often RSA with SHA-256).
  - d: The signing domain.
  - s: The selector that identifies which public key to use from the DNS.
  - h: Lists the header fields included in the signature.
  - b: Contains the actual digital signature (encoded).
  - c: Defines the canonicalization algorithms applied to the header and body, where the first part is for the header and the second for the body.
  - t: A numeric value representing the time the signature was generated.
  - x: Specifies the time after which the signature should no longer be considered valid.
  - l: Indicates the length of the canonicalized body that was used to compute the signature.
  - q: Defines the method used to retrieve the public key. The default is usually `dns/txt`.
  - bh: Contains the hash of the canonicalized body, which is used to verify that the body hasn't been altered.
  - i: Specifies the identity on behalf of which the message is signed, usually in the form of an email address



## • Failed

```
Return-Path: <fitinfo-bounces@list.fit.vut.cz>
Received: from list.fit.vutbr.cz (list.fit.vutbr.cz
[IPv6:2001:67c:1220:809:0:0:93e5:922])
  by kazi.fit.vutbr.cz (8.18.1/8.18.1) with ESMTPS id 51SDLIDc083916
  (version=TLSv1.3 cipher=TLS_AES_256_GCM_SHA384 bits=256 verify=NO);
  Fri, 28 Feb 2025 14:21:18 +0100 (CET)
  (envelope-from fitinfo-bounces@list.fit.vut.cz)
DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/relaxed; d=fit.vut.cz; s=mx1;
t=1740748878; bh=K1p4MAijJ6hVMethbtkkCN53z9/Y20j9zRfW0963V2g=;
h=Date:From:To:Subject:List-Id:List-Archive:List-Help:List-Owner:
List-Post:List-Subscribe:List-Unsubscribe;
b=QjLLJoMX1tu9btGXIBgA85456Tm8W53e1ARmz+CW0DBZp78bVY5nvQD6ucdSC12xw
Tf4ri2A0jQ/KHZ1cuq6TbQDglV+LuAo/vioqE6WnpHJQCCHHrcxcMPBoF+AKbHGr/fk
L9l/gjb0xYGcuTP5/oniYapSrtMOg8ZZtlnVw16Q=
Authentication-Results: list.fit.vutbr.cz;
dkim=fail reason="signature verification failed" (1024-bit key; secure)
header.d=fit.vut.cz header.i=@fit.vut.cz header.a=rsa-sha256
header.s=mx1 header.b=utzXjQ3r; dkim-atps=neutral
```

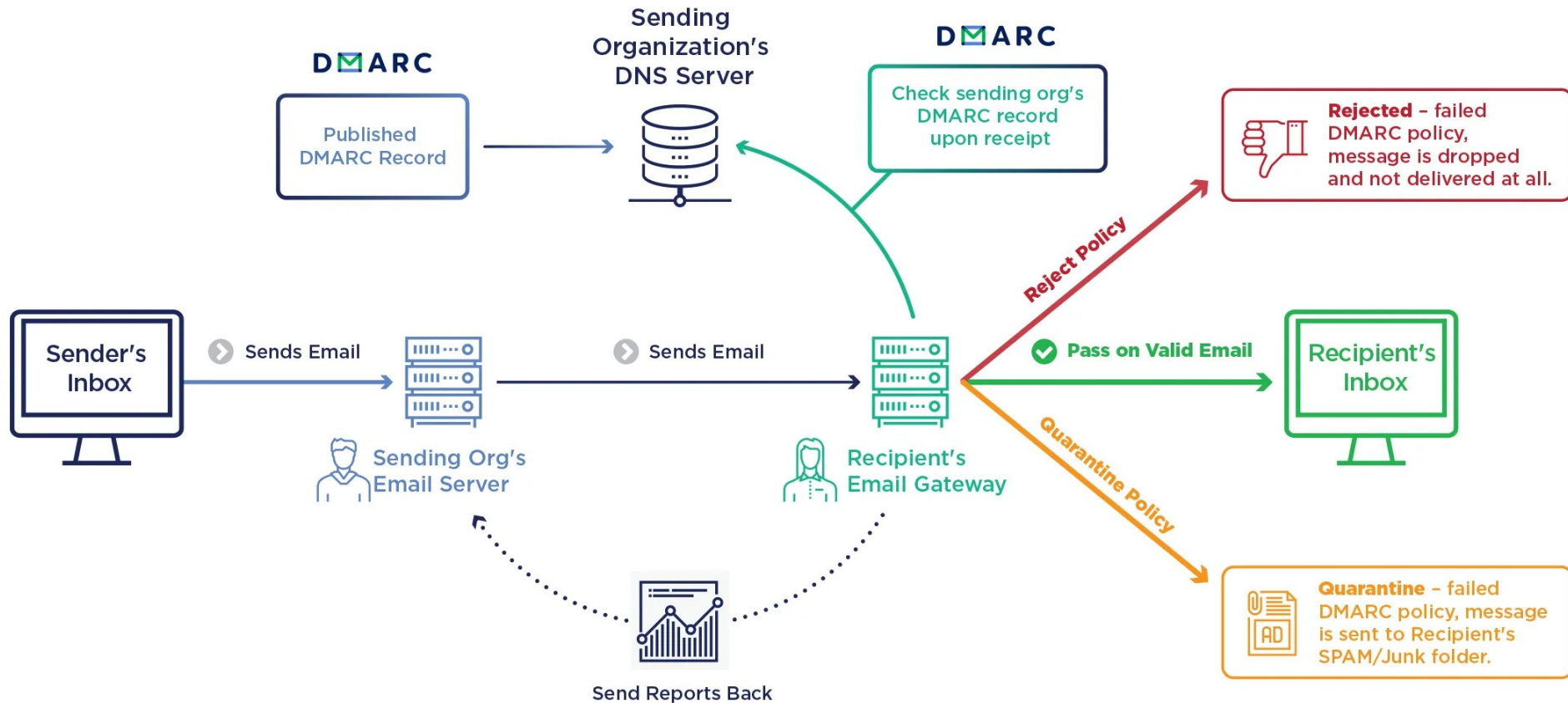
## • Passed

```
Return-Path: <burgetr@fit.vut.cz>
Received: from pcburgetr.localnet (
[IPv6:2001:67c:1220:80c:dc2:bde3:f070:2f0c])
  (authenticated bits=0)
  by kazi.fit.vutbr.cz (8.18.1/8.18.1) with ESMTPSA id 51IDm5bs052616
  (version=TLSv1.3 cipher=TLS_AES_256_GCM_SHA384 bits=256 verify=NO);
  Tue, 18 Feb 2025 14:48:05 +0100 (CET)
  (envelope-from burgetr@fit.vut.cz)
DKIM-Signature: v=1; a=rsa-sha256; c=relaxed/relaxed; d=fit.vut.cz; s=mx1;
t=1739886485; bh=k+3hwkBDxIgk/6V/K+GpnTb1SoBoE694bXmCrWfvNUA=;
h=From:To:Cc:Subject:Date;
b=CAJ2z0ae9x/hmbg3bVXyoGCH4UHIjcn7WpVTRo6/3BtJ/yptPnPwYs3nk8f2qQRBg
sS9+AoBZNiA+eg2tzA6ZvyLBSCdK3vBSdabALXFAKK5tH0If51HEAzJ+UZ7ubeLn20
Oh//thiGURXs3pN7xbdrsG6nScG5gnSaIBW//5zI=
```

# DMARC

- DMARC is defined in RFC 7489 is an email authentication protocol that builds on SPF and DKIM
- Authentication
  - DMARC verifies the authenticity of email senders by aligning the results of SPF and DKIM checks with the domain in the "From" header
- Policy enforcement
  - Domain owners can specify how receiving email servers should handle messages that fail authentication
- Reporting
  - DMARC provides a feedback mechanism, allowing domain owners to receive reports on email authentication results and potential abuse of their domain

- DMARC records are published as DNS TXT records
- They use the following parameters:
  - `v`: Version identifier
  - `p`: Policy for handling unauthenticated emails (`none`, `quarantine`, `reject`)
  - `rua`: Aggregate reporting email address
  - `sp`: Subdomain policy
  - `ruf`: Forensic reporting email address (optional)
  - `fo`: Failure reporting options
  - `pct`: Percentage of messages subject to policy
  - `adkim`: DKIM alignment mode (`strict` or `relaxed`)
  - `aspf`: SPF alignment mode (`strict` or `relaxed`)
- <https://mxtoolbox.com/SuperTool.aspx?action=dmarc%3afit.vutbr.cz&run=toolpage>



- `report_metadata`: Contains information about the reporting organization, contact details, a unique report identifier, and the time period the report covers (expressed in Unix time).
- `policy_published`: Shows the DMARC policy published by the domain owner, including:
  - `domain`: The domain under analysis.
  - `adkim/aspf`: Alignment modes for DKIM and SPF (e.g., "r" for relaxed).
  - `p/sp`: Somain/Subdomain policy applied (e.g., reject).
  - `pct`: The percentage of messages to which the policy is applied.
- `record`: Represents a single set of authentication results:
  - `row`: Contains the IP address of the sender, the number of messages from that IP, and the outcome of policy evaluation (disposition, and whether DKIM and SPF passed or failed).
  - `identifiers`: Specifies the domains found in the envelope (SMTP) and header (mail).
  - `auth_results`: Provides detailed results for DKIM and SPF evaluations for that record.

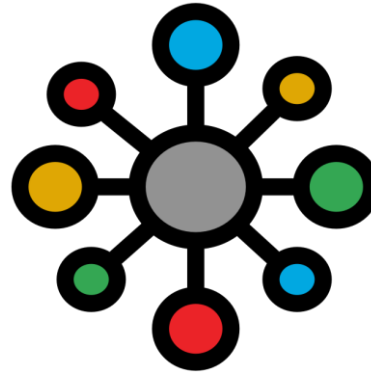
```
<?xml version="1.0" encoding="UTF-8" ?>
<feedback>
  <report_metadata>
    <org_name>example.com</org_name>
    <email>noreply-dmarc-support@example.com</email>
    <extra_contact_info>http://example.com/dmarc/support</extra_contact_info>
    <report_id>9391651994964116463</report_id>
    <date_range>
      <begin>1335571200</begin>
      <end>1335657599</end>
    </date_range>
  </report_metadata>
  <policy_published>
    <domain>bix-business.com</domain>
    <adkim>r</adkim>
    <aspf>r</aspf>
    <p>none</p>
    <sp>none</sp>
    <pct>100</pct>
  </policy_published>
  <record>
    <row>
      <source_ip>203.0.113.209</source_ip>
      <count>2</count>
      <policy_evaluated>
        <disposition>none</disposition>
        <dkim>fail</dkim>
        <spf>pass</spf>
      </policy_evaluated>
    </row>
    <identifiers>
      <header_from>bix-business.com</header_from>
    </identifiers>
    <auth_results>
      <dkim>
        <domain>bix-business.com</domain>
        <result>fail</result>
        <human_result></human_result>
      </dkim>
      <spf>
        <domain>bix-business.com</domain>
        <result>pass</result>
      </spf>
    </auth_results>
  </record>
</feedback>
```

# Q & A

- What is mail user-agent and what features it has? Name examples.
- Describe email structure. What is MIME?
- Describe steps in sending mail from one user and receiving it by another user.
- Describe in detail SMTP protocol.
- What is IMAP? What is POP? How they differ?
- What is S/MIME? What is PGP? How they differ?
- Describe generation and obtaining of PGP key.
- What is SPF and how it protect email exchange?
- What is DKIM and how it protect email exchange?
- What is DMARC and how it protect email exchange?

- <https://www.eecis.udel.edu/~amer/856/smtp.04f.ppt>
- <https://www.geeksforgeeks.org/simple-mail-transfer-protocol-smtp/>
- <https://threatcop.com/blog/spf-authentication/>
- <https://emailauth.io/dkim>
- RHOTON, John. *Programmer's guide to internet mail: SMTP, POP, IMAP, and LDAP*. Digital Press, 1999.

Vladimír Veselý [veselyv@fit.vut.cz](mailto:veselyv@fit.vut.cz)



- výzkumná skupina NES@FIT = specializace NNET
  - <https://www.fit.vut.cz/research/groups/nes@fit/>
- repa s různými projekty
  - <https://nesfit.github.io>
  - <https://git.fit.vutbr.cz/NESFIT>